

Clase 180 — Adversary emulation con Atomic Red Team y Caldera

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *Atomic Red Team (Red Canary) / MITRE Caldera* 🕒 Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Automatizar la emulación de adversarios con dos herramientas complementarias: Atomic Red Team (tests atómicos por técnica ATT&CK) y MITRE Caldera (framework de emulación autónoma con agentes y planificador). El alumno ejecutará pruebas reproducibles en su lab, medirá la detección y cerrará el círculo entre ofensiva y defensa que abre y cierra esta parte.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Ejecutar** tests atómicos de Atomic Red Team mapeados a ATT&CK.
2. **Desplegar** Caldera y lanzar una operación con agentes.
3. **Encadenar** técnicas en un adversary profile de Caldera.
4. **Medir** la detección de cada TTP en el SIEM/EDR.
5. **Automatizar** un ciclo repetible de emulación + validación.

Temas

#	Tema	Por qué importa
1	Atomic Red Team	Tests atómicos por técnica
2	Invoke-AtomicRedTeam	Runner en PowerShell
3	Caldera: server y agentes	Emulación autónoma
4	Abilities y adversary profiles	Encadenar TTPs
5	Planners	Cómo Caldera decide el siguiente paso
6	Validación de detección	Cerrar el ciclo con el SOC
7	Automatización repetible	Emulación continua

Definiciones y características

- **Atomic Red Team:** biblioteca de pruebas pequeñas y aisladas, una por técnica ATT&CK. Característica: reproducibles y fáciles de auditar.
- **Atomic test:** comando/acción concreto que ejerce una técnica. Característica: granular, ideal para validar una detección.

- **Caldera**: plataforma de MITRE para emulación autónoma. Característica: agentes + planificador que ejecutan cadenas de TTPs.
- **Ability**: unidad ejecutable en Caldera ligada a una técnica ATT&CK. Característica: componible en perfiles.
- **Adversary profile**: conjunto ordenado de abilities que emula a un actor. Característica: reutilizable y automatizable.
- **Planner**: lógica que decide qué ability ejecutar a continuación. Característica: da autonomía a la operación.

Herramientas y preparación

- **Atomic Red Team + Invoke-AtomicRedTeam** (módulo PowerShell) en una VM Windows del lab.
- **MITRE Caldera** (Python) en un servidor de lab: `git clone https://github.com/mitre/caldera --recursive && pip install -r requirements.txt`.
- Instrumentación defensiva (Sysmon + SIEM/EDR) de la Clase 178 para validar detecciones.
- ATT&CK Navigator para reflejar la cobertura resultante.

⚠ Atomic Red Team ejecuta acciones ofensivas reales (aunque acotadas): córrelo **solo** en máquinas de laboratorio con snapshots, nunca en producción. Caldera controla agentes: despliégalos únicamente en hosts propios del lab. Revisa siempre qué hace cada test antes de ejecutarlo.

Laboratorio guiado

1. Instala Atomic Red Team:

```
powershell IEX (IWR 'https://raw.githubusercontent.com/redcanaryco/Invoke-AtomicRedTeam/master/install-atomicredteam.ps1' -UseBasicParsing) Install-AtomicRedTeam -getAtomics
```

2. Ejecuta un test atómico. Lanza un test de una técnica de esta parte, p. ej. Kerberoasting o T1059.001 :

```
powershell Invoke-AtomicTest T1558.003 -ShowDetails Invoke-AtomicTest T1558.003
```

Luego limpia con `-Cleanup`. 3. **Valida la detección.** Busca en tu SIEM/EDR el evento asociado y confirma si hubo alerta. 4. **Despliega Caldera.** Arranca el server (`python server.py --insecure`), abre la consola y despliega un agente (Sandcat) en una VM del lab. 5. **Lanza una operación.** Usa un adversary profile existente (p. ej. "Discovery") o crea uno encadenando abilities de discovery → credential access. 6. **Observa la cadena.** Sigue en Caldera qué abilities ejecuta el planner y correlaciona cada una con la telemetría en el SIEM. 7. **Cierra el ciclo.** Marca en Navigator las técnicas emuladas como detectadas/no detectadas y anota qué reglas faltan por crear.

Ejercicios

1. Ejecuta 3 tests atómicos de técnicas distintas y limpia tras cada uno.
2. Para cada test, verifica si tu SIEM lo detecta y anótalo.
3. Despliega un agente Caldera y confírmalo en la consola.
4. Crea un adversary profile con 4 abilities encadenadas.

5. Lanza la operación y documenta la secuencia del planner.
6. Genera una capa de cobertura en Navigator con lo emulado.

Reto verificable

Ejecuta una **campaña de emulación automatizada** en tu lab combinando ambas herramientas: al menos 5 tests atómicos y una operación de Caldera con un perfil de 4+ abilities, validando la detección de cada TTP en tu SIEM/EDR. **Criterio de aceptación:** presentas la salida de los 5 tests atómicos (con su limpieza), la operación de Caldera con su secuencia de abilities, y una capa de Navigator que marca cada técnica emulada como detectada o no, con la regla pendiente para las no detectadas.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Install-AtomicRedTeam falla	ExecutionPolicy o TLS; ajusta la policy en la VM de lab
Un test deja residuos	No corriste <code>-Cleanup</code> ; usa snapshots y limpia siempre
Agente Caldera no aparece	Egress/firewall bloquea; revisa la URL del server y conectividad del lab
El planner no avanza	Faltan facts/requisitos de las abilities; revisa dependencias
Detección incoherente	SIEM sin la fuente de datos; instrumenta antes de emular

Preguntas frecuentes

 **¿Atomic Red Team o Caldera?** Complementarios: Atomic para validar detecciones técnica por técnica; Caldera para emular cadenas de ataque autónomas de un actor. Juntos cubren el espectro.

 **¿Es seguro correr Atomic en cualquier máquina?** No. Ejecuta acciones ofensivas reales; úsalo solo en labs con snapshots y tras leer qué hace cada test. Nunca en producción.

 **¿Esto reemplaza al Red Team humano?** No. Automatiza la emulación repetible y la validación de detecciones, pero la creatividad, el OPSEC y la adaptación al entorno siguen siendo humanas.

Referencias

- Atomic Red Team (Red Canary). <https://github.com/redcanaryco/atomic-red-team> · <https://atomicredteam.io/>
- Invoke-AtomicRedTeam. <https://github.com/redcanaryco/invoke-atomicredteam>
- MITRE Caldera. <https://caldera.mitre.org/> · <https://github.com/mitre/caldera>
- MITRE ATT&CK. <https://attack.mitre.org/>

Siguiente clase

Clase 181 - El SOC moderno: roles, niveles y procesos